COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · On-path Attacks

Mestre CyberSec · **Aula 2.4 — On-path Attacks** (5:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: On-path (antigo man-in-the-middle): atacante fica no MEIO da comunicação e INTERCEPTA ou ALTERA o tráfego. ARP spoofing (mentira no MAC table local — o tráfego passa pelo atacante); evil twin AP; DNS poisoning. Defesa: TLS em tudo (o S importa), VPN em rede pública, ARP inspectio

💡 Highlights que a prova CompTIA cobra

- On-path (antes MITM): intercepta e/ou altera comunicação
- ARP spoofing: mentira o MAC — redireciona tráfego ao atacante
- Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'traffic intercepted between two parties' = on-path/MITM

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — On-path Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque On-Path (antigo Man-in-the-Middle) (MITM)

Ataque em que o adversário se posiciona ENTRE duas partes que se comunicam para interceptar, ler ou alterar o tráfego sem que nenhum dos lados perceba. Antigamente chamado de Man-in-the-Middle (MITM).

⚠️ ***Armadilha CompTIA:*** *Qualquer questão dizendo 'traffic intercepted between two parties' ou 'attacker sits in the middle of communication' = on-path. CompTIA atualizou o nome: MITM e on-path são o mesmo ataque.*

• Falsificação de ARP (ARP Poisoning)

Envio de respostas ARP falsificadas na rede local para associar o endereço MAC do atacante a um IP legítimo (como o gateway padrão), redirecionando o tráfego pela máquina do atacante. Funciona porque o ARP não tem autenticação.

⚠️ ***Armadilha CompTIA:*** *ARP spoofing é o MECANISMO técnico mais cobrado para viabilizar um ataque on-path na LAN. Gatilho: 'MAC table', 'gateway traffic redirected', 'local network interception'. Lembre: ARP não autentica nada — qualquer um pode responder.*

• Gêmeo Maligno (Ponto de Acesso Falso) (AP)

Ponto de acesso sem fio falso configurado para imitar um legítimo (SSID igual ou parecido), enganando usuários para que se conectem — permitindo ao atacante interceptar todo o tráfego. É a forma sem fio do ataque on-path.

⚠️ ***Armadilha CompTIA:*** *Não confunda: Evil Twin = AP falso com SSID legítimo (interceptação); Rogue AP = AP não autorizado plugado na rede corporativa. Gatilho: 'fake Wi-Fi hotspot', 'users connected to malicious access point'.*

• Envenenamento de DNS (DNS Cache Poisoning)

Injeção de registros DNS falsos no cache de um resolvedor, fazendo nomes de domínio legítimos resolverem para IPs controlados pelo atacante, redirecionando usuários silenciosamente para sites maliciosos.

⚠️ ***Armadilha CompTIA:*** *Se a questão fala em 'users redirected to fake site despite typing correct URL', pense em DNS poisoning/spoofing. Defesas cobradas: DNSSEC (autentica as respostas) e validação de respostas DNS.*

• Segurança da Camada de Transporte (TLS)

Protocolo criptográfico que cifra o tráfego e autentica o endpoint do servidor via certificados digitais, derrotando atacantes on-path mesmo quando eles enxergam o tráfego. É o 'S' do HTTPS.

⚠️ ***Armadilha CompTIA:*** *Defesa nº1 contra on-path segundo Messer: 'TLS em tudo — o S importa'. A questão-chave: interceptar não basta, pois com TLS o atacante vê só dados cifrados. Um alerta de certificado inválido no navegador pode indicar um ataque on-path em andamento!*

• Rede Privada Virtual (VPN)

Cria um túnel criptografado entre o cliente e um endpoint confiável, protegendo todo o tráfego contra interceptação em redes não confiáveis como Wi-Fi público — defesa primária contra ataques on-path.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico: 'user on public Wi-Fi / coffee shop / hotel network, how to protect traffic?' = VPN (túnel criptografado). A VPN protege mesmo se o usuário cair num Evil Twin.*

• Inspeção Dinâmica de ARP (DAI)

Recurso de segurança em switches que valida pacotes ARP contra uma tabela de vínculos confiáveis (geralmente construída pelo DHCP snooping) e descarta respostas ARP falsificadas, bloqueando diretamente o ARP spoofing na LAN.

⚠️ ***Armadilha CompTIA:*** *Se a pergunta pedir como PREVENIR ARP spoofing/poisoning em switches = DAI. Memorize a dupla: DHCP snooping constrói a tabela → DAI a usa para validar o ARP. Costuma cair junto.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Ataque On-path / Man-in-the-Middle (MitM)

🏠 **Analogia Intuitiva:** Pense em dois amigos conversando através de bilhetes de papel, mas o carteiro mal-intencionado abre cada envelope, lê os segredos de ambos, pode reescrever frases com mentiras e entrega a carta como se nada tivesse acontecido. Nenhum dos dois percebe que há um intermediário lendo e manipulando toda a conversa.

🔍 **Causa Raiz / Por que foi criado:** Comunicações de rede sem autenticação mútua ou sem criptografia forte de ponta a ponta confiam na infraestrutura de trânsito. O invasor se posiciona lógica ou fisicamente entre as partes para interceptar e modificar o tráfego.

🛡️ **Visão do Auditor de GRC:** Exigir TLS 1.3 obrigatório para todas as comunicações web e APIs; implementar mTLS (Mutual TLS) para comunicação entre serviços internos e proibir conexões remotas fora de VPNs corporativas criptografadas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'adversary intercepts, relays, and potentially alters communications between two entities without their knowledge'. Resposta: On-path Attack (a terminologia oficial adotada pela CompTIA para Man-in-the-Middle).

📌 Envenenamento de ARP (ARP Poisoning / ARP Spoofing)

🏠 **Analogia Intuitiva:** Em uma sala aberta, o protocolo ARP é como alguém perguntar em voz alta: 'Quem aqui é o gerente da agência?'. O gerente de verdade está prestes a falar, mas um estelionatário grita mais rápido: 'Eu sou o gerente e este aqui é o meu crachá físico!'. Os presentes anotam o crachá falso em seus caderninhos e passam a entregar todo o dinheiro diretamente na mão do farsante.

🔍 **Causa Raiz / Por que foi criado:** O protocolo ARP foi concebido sem autenticação na Camada 2 (Enlace). Dispositivos aceitam respostas ARP não solicitadas (gratuitous ARP) e sobrescrevem cegamente suas tabelas ARP em memória de cache.

🛡️ **Visão do Auditor de GRC:** Incluir nas linhas de base de infraestrutura a obrigatoriedade de habilitar Dynamic ARP Inspection (DAI) e DHCP Snooping em todos os switches de acesso da rede local corporativa.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker sends gratuitous ARP replies linking their MAC address with the IP address of the default gateway'. Resposta: ARP Poisoning / ARP Spoofing.

📌 SSL Stripping (Ataque de Downgrade de HTTPS)

🏠 **Analogia Intuitiva:** Você chega na porta de um banco querendo entrar na sala blindada e com isolamento acústico (HTTPS). O recepcionista desonesto diz: 'A sala blindada está em reforma, mas pode falar a sua senha e saldo aqui mesmo no balcão aberto (HTTP) que eu garanto a discrição'. Ele ouve tudo o que você fala e repassa para o banco dentro da sala segura, roubando suas credenciais em texto claro.

🔍 **Causa Raiz / Por que foi criado:** Navegadores frequentemente iniciam requisições em HTTP antes do redirecionamento 301/302 para HTTPS. Um atacante on-path intercepta o tráfego, mantém o canal seguro com o servidor legítimo, mas rebaixa a conexão com a vítima para HTTP não criptografado.

🛡️ **Visão do Auditor de GRC:** Fiscalizar a configuração de cabeçalhos HSTS (HTTP Strict Transport Security) com inclusão na lista pré-carregada (HSTS Preload) em todas as aplicações web públicas da organização.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker intercepts communication and downgrades HTTPS connections to unencrypted HTTP to capture credentials in plaintext'. Resposta: SSL Stripping. Defesa primordial: HSTS.

📌 Defesa com DAI (Dynamic ARP Inspection) e DHCP Snooping

🏠 **Analogia Intuitiva:** O DAI é como o segurança na entrada da empresa que possui o livro oficial de crachás assinado pela administração (banco de dados do DHCP Snooping). Quando alguém grita na sala dizendo que é o diretor financeiro, o segurança confere o livro: 'Falso! Este crachá físico pertence ao estagiário!'. O segurança rasga o bilhete falso e expulsa o farsante na hora.

🔍 **Causa Raiz / Por que foi criado:** Switches comuns apenas encaminham quadros Ethernet sem inspecionar a autenticidade dos dados internos. O DAI inspeciona cada pacote ARP nas portas de acesso não confiáveis, descartando qualquer pacote com mapeamento IP-MAC divergente.

🛡️ **Visão do Auditor de GRC:** Auditar as configurações de rede local com testes de intrusão; validar que portas de computadores de usuários estejam configuradas como 'untrusted' e apenas portas de servidores DHCP legítimos estejam marcadas como 'trusted'.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'switch security feature that prevents ARP poisoning by validating packets against a trusted DHCP binding database'. Resposta: Dynamic ARP Inspection (DAI).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Invasor intercepta e manipula o tráfego entre cliente e servidor sem o conhecimento das partes	**Ataque On-path (Man-in-the-Middle)**
Mensagens ARP Reply falsas associando o endereço MAC do invasor ao IP do gateway da rede	**Envenenamento de ARP (ARP Poisoning / Spoofing)**
Rebaixamento forçado de uma sessão segura HTTPS para o protocolo inseguro HTTP em texto claro	**SSL Stripping (Downgrade Attack)**
Cabeçalho web que instrui o navegador a comunicar-se exclusivamente via HTTPS criptografado	**HSTS (HTTP Strict Transport Security)**
Recurso de hardware em switch que bloqueia pacotes ARP forjados inspecionando portas não confiáveis	**DAI (Dynamic ARP Inspection)**
Técnica de camada 2 que mapeia e armazena os pares legítimos de IP e MAC concedidos por DHCP	**DHCP Snooping**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança de um hospital revisa logs de switch e vê inúmeras respostas ARP em que o mesmo endereço MAC afirma ser o gateway padrão e vários servidores de dispositivos médicos. O tráfego entre os servidores e as estações clínicas está sendo redirecionado silenciosamente. Qual recurso do switch o analista deve habilitar para impedir esse ataque específico?

A) Dynamic ARP Inspection

B) DNSSEC

C) Autenticação de porta 802.1X

D) Modo túnel IPsec

QUESTÃO 2 · CENÁRIO DE EXAME

Um vendedor em viagem se conecta a uma rede sem fio chamada Airport_Free_WiFi em um aeroporto. Logo depois, o navegador exibe um aviso de certificado para o site de webmail da empresa, e suspeita-se que credenciais de login foram roubadas. Investigadores encontram um ponto de acesso malicioso transmitindo o mesmo SSID com sinal mais forte. Qual ataque melhor corresponde a esse cenário?

A) Envenenamento de cache DNS

B) VLAN hopping

C) Evil twin

D) ARP spoofing

QUESTÃO 3 · CENÁRIO DE EXAME

Funcionários de um escritório remoto relatam que digitar o nome do portal interno de folha de pagamento resolve para um endereço IP externo que hospeda uma página de login falsa. O cache do resolvedor DNS interno contém uma entrada que não foi criada pelo servidor autoritativo. Qual controle de segurança valida diretamente as respostas DNS para impedir esse tipo de falsificação de registro?

A) Dynamic ARP Inspection

B) DNSSEC

C) WPA3-Enterprise

D) Port security

QUESTÃO 4 · CENÁRIO DE EXAME

Um funcionário remoto precisa acessar compartilhamentos de arquivos corporativos pelo Wi-Fi aberto de uma cafeteria. A empresa deseja proteger todo o tráfego contra interceptação on-path, incluindo protocolos que não usam criptografia nativamente. Qual solução a equipe de segurança deve exigir?

A) Ocultar o SSID no notebook do funcionário

B) Configurar entradas ARP estáticas para o servidor corporativo

C) Usar somente DNS over HTTPS

D) Uma VPN full-tunnel com autenticação baseada em certificado

QUESTÃO 5 · CENÁRIO DE EXAME

Uma aplicação web está configurada para usar HTTPS, mas usuários em uma rede não confiável às vezes são redirecionados da requisição HTTP inicial para uma página HTTP controlada pelo atacante antes de chegar à página de login. Qual controle previne melhor esse ataque on-path de SSL stripping em visitas futuras?

A) HTTP Strict Transport Security

B) Dynamic ARP Inspection

C) DNSSEC

D) Controle de acesso à rede

QUESTÃO 6 · CENÁRIO DE EXAME

Em uma LAN de campus, vários usuários de repente recebem configuração IP com um endereço de gateway padrão que pertence a um notebook não autorizado. O tráfego deles então é roteado por esse notebook. Qual recurso do switch impede mais diretamente que servidores DHCP maliciosos atribuam configurações de gateway maliciosas?

A) Dynamic ARP Inspection

B) DHCP snooping

C) Private VLANs

D) Spanning Tree Protocol

QUESTÃO 7 · CENÁRIO DE EXAME

Um administrador planeja habilitar Dynamic ARP Inspection em switches de acesso para impedir ARP spoofing. Os switches atualmente não têm recursos de segurança de Camada 2 configurados. Qual configuração normalmente é necessária para que o DAI valide pacotes ARP com base em associações confiáveis?

A) Filtragem de rotas BGP

B) Inspeção TLS

C) DHCP snooping

D) Autenticação RADIUS para todos os usuários

QUESTÃO 8 · CENÁRIO DE EXAME

Um testador de penetração na mesma VLAN que um alvo usa respostas ARP forjadas para fazer o alvo acreditar que o endereço MAC do testador é o gateway. O testador então encaminha pacotes para o gateway real enquanto os captura. Qual termo descreve melhor esse ataque?

A) Ataque de negação de serviço

B) Injeção SQL

C) Cross-site scripting

D) Ataque on-path

QUESTÃO 9 · CENÁRIO DE EXAME

Notebooks corporativos estão configurados para entrar automaticamente em qualquer rede sem fio chamada CompanyGuest. Um atacante monta um AP malicioso com esse nome perto do saguão de um hotel. Qual mudança de configuração reduz mais diretamente o risco de os notebooks se conectarem ao AP malicioso?

A) Desabilitar conexão automática a SSIDs abertos ou não confiáveis e exigir perfis gerenciados

B) Habilitar port security em todos os switches de acesso

C) Substituir DNSSEC por DNS over HTTP

D) Ativar Spanning Tree Protocol nos controladores sem fio

QUESTÃO 10 · CENÁRIO DE EXAME

Um funcionário ignora um aviso do navegador sobre um certificado não confiável ao usar Wi-Fi público. Mais tarde, um analista de segurança descobre que a sessão foi descriptografada por um atacante que apresentou um certificado autoassinado. Qual ação do usuário teria impedido mais diretamente a interceptação?

A) Habilitar filtragem de endereço MAC

B) Parar e não prosseguir quando o aviso de certificado apareceu

C) Ocultar o SSID sem fio

D) Desabilitar o firewall local

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Dynamic ARP Inspection

A Dynamic ARP Inspection valida pacotes ARP em portas não confiáveis do switch usando a tabela de binding do DHCP snooping ou ACLs ARP estáticas. Ela descarta respostas ARP forjadas que associam o IP do gateway ao MAC do atacante, prevenindo o redirecionamento on-path local. DNSSEC protege registros DNS, 802.1X controla acesso à rede, e IPsec não impede envenenamento ARP na LAN.

Questão 2: Alternativa C — Evil twin

Um evil twin é um ponto de acesso malicioso que se passa por um SSID legítimo para atrair clientes. O sinal mais forte e o aviso de certificado no site corporativo são consistentes com o cliente conectando-se ao AP do atacante e sendo interceptado. Envenenamento de cache DNS afeta resolução de nomes, ARP spoofing é camada 2 em uma LAN, e VLAN hopping é um ataque de comutação, não um AP sem fio falso.

Questão 3: Alternativa B — DNSSEC

O DNSSEC fornece assinaturas criptográficas para registros DNS, permitindo que resolvedores validadores detectem respostas forjadas ou alteradas. DAI protege ARP, WPA3-Enterprise protege enlaces sem fio, e port security limita endereços MAC em portas de switch; nenhum valida a autenticidade de registros DNS.

Questão 4: Alternativa D — Uma VPN full-tunnel com autenticação baseada em certificado

Uma VPN full-tunnel criptografa todo o tráfego do endpoint até o gateway corporativo, protegendo até protocolos sem criptografia contra interceptação on-path em Wi-Fi público. Ocultar SSIDs, entradas ARP estáticas e apenas DoH não protegem o tráfego geral. DoH protege somente consultas DNS.

Questão 5: Alternativa A — HTTP Strict Transport Security

O HSTS instrui os navegadores a usar somente HTTPS para um domínio e impede ataques de downgrade de protocolo, como SSL stripping, após a primeira visita confiável. DAI, DNSSEC e NAC tratam de camadas diferentes e não impedem um downgrade de HTTP para HTTPS na camada de aplicação.

Questão 6: Alternativa B — DHCP snooping

O DHCP snooping designa portas confiáveis do switch para servidores DHCP e bloqueia ofertas DHCP de portas não confiáveis, impedindo que servidores DHCP maliciosos atribuam gateway ou DNS maliciosos. DAI protege ARP, private VLANs restringem isolamento de camada 2, e STP previne loops.

Questão 7: Alternativa C — DHCP snooping

O DAI normalmente depende do banco de dados de binding do DHCP snooping para saber quais mapeamentos IP-para-MAC são válidos em cada porta. ACLs ARP estáticas podem ser usadas em alguns projetos, mas o DHCP snooping é o pré-requisito padrão. Filtragem BGP, inspeção TLS e autenticação RADIUS não fornecem bindings para DAI.

Questão 8: Alternativa D — Ataque on-path

Forjar respostas ARP para inserir o atacante entre a vítima e o gateway, e depois encaminhar o tráfego enquanto o captura, é um ataque on-path, frequentemente chamado de man-in-the-middle. Não é primariamente DoS, injeção SQL ou XSS.

Questão 9: Alternativa A — Desabilitar conexão automática a SSIDs abertos ou não confiáveis e exigir perfis gerenciados

Desabilitar conexões automáticas a SSIDs abertos ou não confiáveis e exigir perfis sem fio gerenciados impede que clientes entrem silenciosamente em um evil twin. Port security, DNS over HTTP e STP não impedem a associação de clientes sem fio a um AP malicioso.

Questão 10: Alternativa B — Parar e não prosseguir quando o aviso de certificado apareceu

O TLS protege contra interceptação on-path somente quando o cliente valida o certificado do servidor. Prosseguir após um aviso de certificado não confiável permite que um atacante com certificado autoassinado encerre e leia a sessão TLS. Filtragem MAC, ocultação de SSID e desabilitar o firewall não corrigem a validação de certificado.